



Circular CSSF 25/893

on reporting of major ICT-related incidents and significant cyber threats under the Digital Operational Resilience Act (DORA)

Circular CSSF 25/893

on reporting of major ICT-related incidents and significant cyber threats under the Digital Operational Resilience Act (DORA)

To all financial entities defined in Article 2(1)(a) to (i), (k) to (m), (p), (r) and (s), and within the meaning of Article 2(2) of Regulation (EU) 2022/2554¹ on digital operational resilience for the financial sector (hereafter "DORA") and to all Payment Service Providers as referred to in Article 1(37) of the Law of 10 November 2009 on payment services (LPS).

Luxembourg, 27 May 2025

Ladies and Gentlemen,

As defined in Articles 18(1), 18(2), 19(1) and 19(2) of DORA, financial entities subject to DORA are required to comply with the obligations for classifying and reporting major ICT-related incidents and, if applicable, significant cyber threats. The specifics regarding classification and reporting are detailed in the following Regulatory Technical Standards (RTS) and Implementing Technical Standards (ITS):

- RTS on classification of ICT-related incidents and cyber threats² (hereafter "RTS on classification"), and
- RTS and ITS on incident and voluntary cyber threats reporting (hereafter "RTS on incident reporting"³ and "ITS on incident reporting"⁴)

Furthermore, with this circular the CSSF requires Payment Service Providers (PSPs) that are not in the scope of DORA to follow the ICT-related incident and cyber threat classification and reporting procedures under DORA in order to fulfil the reporting requirements stipulated under Article 105-2 of the LPS. As a simplification, these PSPs shall follow the DORA requirements for all ICT-related incidents (i.e. including ICT-related incident not related to payment services), so as to avoid a dual reporting scheme.

In this context, this circular also provides the practical modalities according to which financial entities in scope of this circular are required to notify the major ICT-related incidents as well as, if applicable, significant cyber threats to the CSSF.

¹ Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector and amending Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014 and (EU) 2016/1011

² Commission Delegated Regulation (EU) 2024/1772 of 13 March 2024 supplementing Regulation (EU) 2022/2554 of the European Parliament and of the Council with regard to regulatory technical standards specifying the criteria for the classification of ICT-related incidents and cyber threats, setting out materiality thresholds and specifying the details of reports of major incidents

³ Commission Delegated Regulation (EU) 2025/301 of 23 October 2024 supplementing Regulation (EU) 2022/2554 of the European Parliament and of the Council with regard to regulatory technical standards specifying the content and time limits for the initial notification of, and intermediate and final report on, major ICT-related incidents, and the content of the voluntary notification for significant cyber threats

⁴ Commission Implementing Regulation (EU) 2025/302 of 23 October 2024 laying down implementing technical standards for the application of Regulation (EU) 2022/2554 of the European Parliament and of the Council with regard to the standard forms, templates, and procedures for financial entities to report a major ICT-related incident and to notify a significant cyber threat

This circular is divided into four chapters:

- Chapter 1 defines the scope of application;
- Chapter 2 lists the requirements on classification and reporting of incident and cyber threats for PSPs not under DORA;
- Chapter 3 defines the practical modalities for the reporting of major ICT-related incidents and significant cyber threats;
- Chapter 4 provides for the entry into force of this circular.

TABLE OF CONTENTS

Chapter 1:	Scope of application	5
Chapter 2:	Requirements on classification and reporting of incident and cyber threats for PSPs not under DORA.....	6
Chapter 3:	Practical modalities for major ICT-related incident notification and significant cyber threats reporting.....	7
Chapter 4:	Date of application	8

Chapter 1: Scope of application

1. The following entities are to be considered as financial entities in the framework of this circular:
 - a) credit institutions, investment firms, market operators operating a trading venue and approved publication arrangements (APAs) with a derogation and authorised reporting mechanisms (ARMs) with a derogation within the meaning of the Law of 5 April 1993 on the financial sector (LFS);
 - b) payment institutions, account information service providers and electronic money institutions within the meaning of the Law of 10 November 2009 on payment services (LPS);
 - c) crypto asset service providers and issuers of asset-referenced tokens within the meaning of Regulation (EU) 2023/1114;
 - d) central securities depositories within the meaning of the Law of 6 June 2018 on central securities depositories (CSD Law);
 - e) central counterparties within the meaning of the Law of 15 March 2016 on OTC derivatives, central counterparties and trade repositories;
 - f) management companies incorporated under Luxembourg law and subject to Chapter 15 or Article 125-2 of Chapter 16, and Luxembourg branches of investment fund managers subject to Chapter 17, and investment companies which did not designate a management company within the meaning of Article 27 of the Law of 17 December 2010 relating to undertakings for collective investment;
 - g) alternative investment fund managers authorised under Chapter 2 and internally managed alternative investment funds within the meaning of point (b) of Article 4(1) of the Law of 12 July 2013 on alternative investment fund managers (AIFM Law);
 - h) institutions for occupational retirement provisions authorised in accordance with Article 2(2) of the Law of 13 July 2005 on institutions for occupational retirement provision in the form of pension savings companies with variable capital (SEPCAVs) and pension savings associations (ASSEPs);
 - i) administrators of critical benchmarks within the meaning of point (b) of Article 20(1) of Regulation (EU) 2016/1011;
 - j) crowdfunding service providers within the meaning of the Law of 16 July 2019 on the operationalisation of European regulations in the area of financial services;
 - k) Payment Service Providers (PSPs) as referred to in Article 1(37) of the Law of 10 November 2009 on payment services (LPS) that are not financial entities as defined in point 1 (a) and (b) above, i.e. branches in Luxembourg of PSPs incorporated in a third country, and POST Luxembourg.
2. The provisions of Chapter 2 of this circular are only applicable to entities in scope as defined in point (k) above, hereafter collectively referred to as **"PSPs not under DORA"**.
3. The provisions of Chapter 3 of this circular are applicable to all financial entities in scope as defined in point 1 (a) to (k) above, hereafter collectively referred to as **"Financial Entities"** or individually as **"Financial Entity"**, including their branches as specified in the respective laws.

4. Branches in Luxembourg of the Financial Entities that are part of a legal entity whose head office is located in a different Member State of the European Union (EU branches) are expected to report their major ICT-related incidents and significant cyber threats under DORA to the competent authority of that Member State (home Member State) and are therefore excluded from the scope of this circular.

Chapter 2: Requirements on classification and reporting of incident and cyber threats for PSPs not under DORA

5. For the purpose of this circular, the following definitions are derived from the DORA regulation and apply for PSPs not under DORA:
 - a) 'network and information system' means:
 - (1) an 'electronic communications network': transmission systems, whether or not based on a permanent infrastructure or centralised administration capacity, and, where applicable, switching or routing equipment and other resources, including network elements which are not active, which permit the conveyance of signals by wire, radio, optical or other electromagnetic means, including satellite networks, fixed (circuit- and packet-switched, including internet) and mobile networks, electricity cable systems, to the extent that they are used for the purpose of transmitting signals, networks used for radio and television broadcasting, and cable television networks, irrespective of the type of information conveyed;
 - (2) any device or group of interconnected or related devices, one or more of which, pursuant to a programme, carry out automatic processing of digital data; or
 - (3) digital data stored, processed, retrieved or transmitted by elements covered under points (1) and (2) for the purposes of their operation, use, protection and maintenance;
 - b) 'security of network and information systems' means the ability of network and information systems to resist, at a given level of confidence, any event that may compromise the availability, authenticity, integrity or confidentiality of stored, transmitted or processed data or of the services offered by, or accessible via, those network and information systems;
 - c) 'operational or security payment-related incident' means a single event or a series of linked events unplanned by the financial entities, whether ICT-related or not, that has an adverse impact on the availability, authenticity, integrity or confidentiality of payment-related data, or on the payment-related services provided by the financial entity;
 - d) 'ICT-related incident' means a single event or a series of linked events unplanned by the financial entity that compromises the security of the network and information systems, and have an adverse impact on the availability, authenticity, integrity or confidentiality of data, or on the services provided by the financial entity. This includes operational or security payment-related incidents;
 - e) 'major operational or security payment-related incident' means an operational or security payment-related incident that has a high adverse impact on the payment-related services provided;

- f) 'major ICT-related incident' means an ICT-related incident that has a high adverse impact on the network and information systems that support critical or important functions of the financial entity. This includes major operational or security payment-related incidents;
 - g) 'cyber threat' means any potential circumstance, event or action that could damage, disrupt or otherwise adversely impact network and information systems, the users of such systems and other persons;
 - h) 'significant cyber threat' means a cyber threat the technical characteristics of which indicate that it could have the potential to result in a major ICT-related incident or a major operational or security payment-related incident;
 - i) 'critical or important function' means a function, the disruption of which would materially impair the financial performance of a financial entity, or the soundness or continuity of its services and activities, or the discontinued, defective or failed performance of that function would materially impair the continuing compliance of a financial entity with the conditions and obligations of its authorisation, or with its other obligations under applicable financial services law.
6. PSPs not under DORA are required to classify their ICT-related incidents and their cyber threats according to the criteria and materiality thresholds as defined in Chapters I, II and III of the RTS on classification. Chapters IV and V of the RTS on classification are not applicable to them.
7. PSPs not under DORA are further required to notify the major ICT-related incidents and, if applicable, significant cyber threats, according to the RTS on incident reporting and to the ITS on incident reporting, which apply in full to them.

Chapter 3: Practical modalities for major ICT-related incident notification and significant cyber threats reporting

8. Major ICT-related incident notifications as well as, if applicable, significant cyber threats, shall be submitted via the corresponding form either through the dedicated procedure "DORA Major ICT-related Incident Notification" available on the CSSF eDesk Portal or via the API interface (S3) provided by the CSSF.
9. Financial entities shall notify the CSSF according to the time limits laid down in Article 5 of the RTS on incident reporting.
10. Financial entities shall complete the relevant section(s) of the notification form, depending on the phase they are in. The first section refers to the initial notification as per Article 2 of the RTS on incident reporting, the second section refers to the intermediate report as per Article 3 of the RTS on incident reporting and the third section refers to the final report as per Article 4 of the RTS on incident reporting. The notification form contains the data fields laid down in Annexes II and IV of the ITS on incident reporting.
11. Article 7 of the ITS on incident reporting indicates that aggregated reporting is only possible if competent authorities have explicitly given the permission. In this regard, the CSSF informs financial entities that, after having carefully evaluated all of the conditions from points (a) to (d) of Article 7(1) as well as Article 7(2) of the ITS on incident reporting, no aggregated report is permitted when it comes to major ICT-related incident notifications.

12. Financial entities that have outsourced the reporting obligations remain fully responsible for the fulfilment of incident reporting requirements within the applicable timeline and for the whole content of the notification forms. As specified in Article 6 of the ITS on incident reporting, financial entities shall inform the CSSF as soon as possible of outsourcing of reporting obligations and at the latest prior to the first notification. In this regard, the following details must be provided to the CSSF (email address: ictrisksupervision@cssf.lu):
- a) Name, contact details and an identification code of the third party that will submit the notifications on behalf of the financial entity;
 - b) Name, contact details and the related function of the persons at the third party to whom the related incident notification role will be assigned in the CSSF digital solution.

Chapter 4: Date of application

13. For entities listed under points 1(a) to (j):
- a) This circular shall apply with immediate effect and renders Circular CSSF 24/847 on ICT-related incident reporting framework no longer applicable to them;
 - b) Circular CSSF 21/787 on application of the EBA Guidelines (EBA/GL/2021/03) on major incident reporting under PSD2 is no longer applicable to them.
14. For entities listed under point 1(k):
- a) This circular shall apply six months after its publication date;
 - b) During the transition period, the classification criteria as well as the notification reporting modalities as required by Circulars CSSF 24/847 on ICT-related incident reporting framework and CSSF 21/787 on application of the EBA Guidelines (EBA/GL/2021/03) on major incident reporting under PSD2 remain applicable to them.
15. Six months after the publication date of this circular, Circular CSSF 21/787 on application of the EBA Guidelines (EBA/GL/2021/03) on major incident reporting under PSD2 will be repealed.

Claude WAMPACH
Director

Marco ZWICK
Director

Jean-Pierre FABER
Director

Françoise KAUTHEN
Director

Claude MARX
Director General